

UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

MATRIZ SANGOLQUÍ

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN CARRERA DE INGENIERÍA EN SOFTWARE

Título:	Activos y Riesgos de Software
Autores:	• Ariel Morillo • Matias Lugmaña • Alexander Villacrés
Carrera:	Ingeniería en Software
Asignatura:	Desarrollo de Software Seguro
Docente:	Ing Angel Cudco.
Fecha de entrega:	12/10/2026

Análisis de riesgos de la aplicación de salas de chat seguras

1. Contexto y supuestos. Se evalúa una aplicación de chat con administrador autenticado, salas con identificador único y clave independiente, cupo máximo y modalidad de texto, multimedia o ambas. Se asume una red no confiable. La cuarentena se propone como política del equipo, entre las alternativas permitidas por el postulado. Para exigir un dispositivo por usuario/sesión debe definirse una identidad verificable: un identificador arbitrario enviado por el cliente no demuestra identidad. El registro de vínculo al dispositivo es una propuesta de diseño para cumplir ese requisito.

2. Método y escala. Se plantea un riesgo por activo. Las amenazas, vulnerabilidades y puntuaciones son escenarios considerados por nuestro criterio . P: 1 rara, 2 poco probable, 3 posible, 4 probable y 5 muy probable. I: 1 mínimo, 2 menor, 3 moderado, 4 grave y 5 crítico. Cada fila justifica su valoración inicial. Riesgo inicial R = P × I. Puntaje normalizado S = (R / 25) × 10. Se adoptan los rangos vistos en clase como prioridades internas: Baja 0,1–3,9; Media 4,0–6,9; Alta 7,0–8,9; Crítica 9,0–10. Cero representa ausencia de riesgo y no se usa en estos escenarios. La normalización no constituye una puntuación CVSS, sino solo ajustada a nuestro caso pero se tomó en cuenta al CVSS.

3. Tratamiento. Se propone mitigar los riesgos con los controles y responsables indicados. Zero Trust se concreta en validar identidad, sesión y autorización en cada operación; Secure by Design, en incluir criptografía, aislamiento y restricciones de unicidad desde el diseño; Shift Left Security, en incorporar las pruebas de abuso y revisión de controles durante el desarrollo. El inventario, tratamiento y seguimiento se relacionan con la gestión de seguridad solicitada bajo ISO/IEC 27001; los requisitos y pruebas de la aplicación, con el enfoque de seguridad de aplicaciones solicitado bajo ISO/IEC 27034.

4. Reevaluación y residual. La columna posterior al tratamiento presenta indicadores propuestos y justifica Pr e Ir como valores condicionales. No hay pruebas realizadas ni controles implementados en este análisis. Después de implementar, se deben comprobar los indicadores y volver a asignar Pr e Ir con la misma escala; sólo entonces se valida el residual Rr = Pr × Ir y Sr = (Rr / 25) × 10. Los valores actuales son proyecciones según nuestro criterios pero obviamente se debe realizar esto con el software final, así que pendientes de esa comprobación. Se conserva Ir porque no se ha demostrado una reducción del daño si el evento ocurre. Como criterio académico propuesto, una prioridad residual Media o superior requiere más tratamiento o una decisión explícita del responsable; una Baja sólo puede aceptarse después de verificar los controles. Cumplir un porcentaje de pruebas no equivale directamente a la probabilidad real del riesgo.

15 activos y riesgos de la aplicación de salas de chat seguras

Los tipos utilizados son Información, Datos, Software, Servicio e Infraestructura. Se distinguen las claves de ingreso a una sala de las claves criptográficas. La cuarentena es una propuesta de diseño permitida por el postulado. A cada activo A01–A15 le corresponde el riesgo R01–R15.

ID	Activo	Tipo	Consecuencias de acceso, modificación o indisponibilidad	Amenazas principales	Control propuesto
A01	Credenciales de autenticación del administrador	Información	Acceso: toma de la cuenta administrativa. Modificación: cambio de credenciales y bloqueo del administrador. Indisponibilidad: no se podrían gestionar las salas.	1. Adivinación de contraseñas mediante intentos automatizados. 2. Phishing para robar credenciales administrativas. 3. Extracción y ataque de hashes almacenados con protección insuficiente.	Exigir MFA administrativa, límites por cuenta y origen, hash de contraseñas con sal y recuperación de acceso protegida. Responsable: equipo de autenticación.
A02	Claves de acceso independientes de las salas	Información	Acceso: ingreso de personas ajenas a una sala. Modificación: bloqueo o admisión indebida de participantes. Indisponibilidad: no se podrían validar nuevos ingresos.	1. Adivinación automatizada de la clave de una sala. 2. Filtración de claves en registros, enlaces o respuestas.	Usar claves independientes con longitud suficiente, almacenar sus verificadores con hash, limitar intentos y cambiar la clave cuando pierda

				3. Reutilización de claves antiguas por participantes retirados.	confidencialidad. Responsable: equipo de acceso a salas.
A03	Configuración e identificadores de salas	Datos	Acceso: exposición de identificadores y parámetros internos. Modificación: cambio de cupo, modalidad o estado de una sala. Indisponibilidad: no se podrían consultar ni configurar salas.	1. Creación accidental de identificadores duplicados. 2. Modificación no autorizada del tipo de comunicación o cupo. 3. Borrado o corrupción de la configuración de salas.	Generar identificadores únicos en el servidor, imponer unicidad en el almacenamiento, validar modalidad y cupo y registrar cambios autorizados. Responsable: equipo de gestión de salas.
A04	Registro del vínculo entre usuario o sesión y dispositivo	Datos	Acceso: exposición de asociaciones de usuarios/sesiones y dispositivos. Modificación: sustitución del dispositivo autorizado. Indisponibilidad: no se podría comprobar el vínculo activo.	1. Suplantación mediante identificadores de usuario o dispositivo aportados por el cliente. 2. Cambio no autorizado del vínculo de dispositivo. 3. Eliminación de vínculos para eludir la	Mantener el vínculo en un registro autoritativo del servidor, asociarlo a una identidad verificable y exigir autenticación para cambiarlo; revocar el vínculo anterior. Responsable: equipo de

				restricción de conexión.	identidad y sesiones.
A05	Tokens de sesión y estado de conexiones activas	Información	Acceso: reutilización del token para tomar una sesión. Modificación: sesiones falsas o alteradas. Indisponibilidad: desconexión de usuarios y fallos de continuidad.	1. Robo y reutilización de tokens de sesión. 2. Uso de tokens después de cerrar sesión por revocación incompleta. 3. Fijación de sesión por reutilización de identificadores predecibles.	Emitir tokens impredecibles y de vigencia limitada, proteger su almacenamiento y transporte, revocarlos al cerrar sesión o cambiar de dispositivo. Responsable: equipo de sesiones.
A06	Mensajes de texto de las salas	Información	Acceso: lectura de conversaciones privadas. Modificación: falsificación de contenido o autor. Indisponibilidad: pérdida o retraso de la comunicación.	1. Lectura no autorizada de mensajes de otra sala. 2. Alteración de mensajes o falsificación del autor. 3. Repetición de mensajes antiguos para confundir la conversación.	Autenticar al emisor desde su sesión, usar cifrado autenticado en un protocolo revisado y vincular sala, autor y secuencia; rechazar alteraciones y repeticiones. Responsable: equipo de mensajería.
A07	Archivos multimedia cargados y compartidos	Datos	Acceso: descarga de archivos privados. Modificación: sustitución por	1. Carga de contenido activo malicioso	Permitir solo formatos definidos, verificar tipo real y tamaño,

			archivos peligrosos o corruptos. Indisponibilidad: fallos en la transferencia o visualización.	disfrazado de imagen. 2. Archivos malformados que explotan el procesador multimedia. 3. Archivos excesivos o comprimidos que agotan recursos.	procesar en un entorno aislado y entregar sin ejecución de contenido activo. Responsable: equipo de multimedia.
A08	Servicio de transporte de comunicaciones	Servicio	Acceso: interceptación del tráfico entre clientes y servidor. Modificación: alteración o suplantación del canal. Indisponibilidad: interrupción de mensajes y archivos.	1. Intercepción mediante conexiones sin cifrado. 2. Suplantación del servidor con un certificado no validado. 3. Interrupción o saturación de los canales de comunicación.	Exigir transporte cifrado y autenticado, por ejemplo HTTPS/WSS con TLS; validar certificados y rechazar conexiones inseguras. Responsable: equipo de comunicaciones.
A09	Claves criptográficas de cifrado y autenticación	Información	Acceso: descifrado o suplantación según el protocolo. Modificación: mensajes inválidos o claves sustituidas. Indisponibilidad: imposibilidad de proteger o	1. Filtración de claves en código, archivos o registros. 2. Reutilización de una clave global entre salas.	Separar claves por alcance, almacenarlas de forma protegida, evitar su registro y distribuirlas por canales

			recuperar comunicaciones.	3. Uso de claves antiguas después de cambios de participantes.	autenticados; definir renovación y revocación según el protocolo. Responsable: equipo de criptografía.
A10	Módulo de administración de salas	Software	Acceso: uso indebido de funciones administrativas. Modificación: creación, alteración o cierre malicioso de salas. Indisponibilidad: pérdida de la capacidad de administración.	1. Invocación de funciones administrativas sin autorización. 2. Manipulación de solicitudes para cerrar o alterar salas. 3. Explotación de vulnerabilidades en el módulo administrativo.	Autenticar y autorizar cada operación en el servidor, separar el rol administrativo y registrar cambios; confirmar operaciones destructivas. Responsable: equipo de administración.
A11	Servicio de admisión y autorización por sala	Servicio	Acceso: ingreso o uso de una sala ajena. Modificación: membresías o permisos incorrectos. Indisponibilidad: bloqueo de ingresos legítimos.	1. Acceso cruzado entre salas mediante identificadores manipulados. 2. Admisión sin validar la clave correspondiente. 3. Superación del cupo por controles de	Comprobar membresía y permiso en cada operación, vincular solicitudes a la sesión y sala autorizadas y validar cupo de forma atómica al ingresar. Responsable:

				admisión insuficientes.	equipo de autorización.
A12	Gestor de exclusividad de dispositivo y cierre de sesiones	Servicio	Acceso: administración indebida de conexiones. Modificación: múltiples dispositivos activos para la misma identidad. Indisponibilidad: sesiones bloqueadas o desconectadas.	1. Conexiones simultáneas que explotan una condición de carrera. 2. Sesiones obsoletas que no se eliminan al desconectar. 3. Reconexión con un token revocado o desde otro dispositivo.	Usar un registro autoritativo con unicidad y actualización atómica; rechazar la segunda conexión o reemplazar la anterior según política, revocando sus tokens. Responsable: equipo de sesiones.
A13	Módulo de validación y detección de esteganografía	Software	Acceso: revelación o manipulación del funcionamiento del analizador. Modificación: omisión de verificaciones. Indisponibilidad: archivos sin analizar o transferencias bloqueadas.	1. Falsos negativos ante técnicas de ocultación no contempladas. 2. Falsos positivos que bloquean contenido legítimo. 3. Agotamiento de recursos o explotación del analizador.	Definir formatos y técnicas cubiertas, combinar validaciones y estegoanálisis y poner en cuarentena los sospechosos; evaluar con un corpus etiquetado. Responsable: equipo de análisis multimedia.
A14	Almacenamiento aislado de cuarentena de	Infraestructura	Acceso: descarga de archivos retenidos. Modificación:	1. Descarga de archivos en cuarentena mediante	Mantener cuarentena privada y separada, sin

	archivos sospechosos		sustitución o liberación indebida de muestras. Indisponibilidad: imposibilidad de aislar o revisar archivos.	enlaces directos. 2. Ejecución accidental de contenido sospechoso almacenado. 3. Liberación o borrado de muestras por permisos excesivos.	ejecución ni rutas de descarga para participantes; autorizar revisión y liberación con auditoría. Responsable: equipo de almacenamiento multimedia.
A15	Registros de auditoría y alertas de seguridad	Datos	Acceso: exposición de eventos e identificadores operativos. Modificación: ocultación o falsificación de evidencias. Indisponibilidad: pérdida de detección y trazabilidad.	1. Borrado o alteración de eventos para ocultar actividad. 2. Inyección de entradas falsas en registros. 3. Saturación del almacenamiento o supresión de alertas.	Centralizar registros de solo anexado, separar permisos y alertar pérdidas de eventos; registrar acciones sin guardar claves, tokens ni contenido privado innecesario. Responsable: equipo de monitoreo.

Matriz de los 15 riesgos

ID	Activo y tipo	1 Contexto y alcance	2 Riesgo y vulnerabilidad	P	I	Riesgo inicial y justificación	3 Tratamiento y responsable	Reevaluación propuesta: indicador y justificación de Pr e Ir	4 Residual estimado y estado
R01	Credenciales de autenticación del administrador (Información)	Autenticación del administrador. Confidencialidad y control de todas las salas.	Un atacante adivina o reutiliza una contraseña y toma la cuenta administrativa porque faltan MFA y límites efectivos de intentos.	4	5	20 Alta. El acceso administrativo es un objetivo expuesto en el escenario supuesto; su compromiso permite actuar sobre todas las salas.	Mitigar: Exigir MFA administrativa, límites por cuenta y origen, hash de contraseñas con sal y recuperación de acceso protegida. Responsable: equipo de autenticación.	Indicador propuesto: MFA en el 100 % de cuentas administrativas; 100 % de pruebas de límite de intentos y recuperación protegida superadas. **Pr=2:** Los controles reducen adivinación y uso de contraseñas robadas, pero persisten phishing y robo de sesión.**Ir=5:**	Proyección: 2 × 5 = 10 Media.

								Una cuenta administrativa comprometida conserva capacidad de afectar todas las salas.	
R02	Claves de acceso independientes de las salas (Información)	Validación del identificador y clave de ingreso de cada sala. Confidencialidad y autorización.	Un atacante adivina una clave débil mediante intentos repetidos sin límite y entra en una sala privada.	4	4	16 Alta. La clave compartida puede probarse repetidamente si no hay límites; su compromiso expone la comunicación de la sala afectada.	Mitigar: Usar claves independientes con longitud suficiente, almacenar sus verificadores con hash y sal, limitar intentos y cambiar la clave cuando pierda confidencialidad. Responsable: equipo de acceso a salas.	Indicador propuesto: Todas las claves cumplen la política definida; 100 % de pruebas de intentos excesivos bloqueadas y de clave inválida rechazadas.**Pr= 1:** Una clave resistente y límites comprobados hacen menos viable la adivinación; permanece posible una	Proyección: 1 × 4 = 4 Baja.

								filtración por un participante.**Ir= 4:** Conocer una clave válida todavía permitiría acceder al contenido de esa sala.	
R03	Configuración e identificadores de salas (Datos)	Identificador único, cupo, modalidad texto/multimedia y estado de cada sala. Integridad.	Un identificador duplicado aceptado por falta de una restricción de unicidad asocia participantes a una sala equivocada y expone su comunicación.	3	4	12 Media. La colisión es posible al crear salas sin validar unicidad; una asociación errónea puede mezclar participantes y mensajes.	Mitigar: Generar identificadores únicos en el servidor, imponer unicidad en el almacenamiento, validar modalidad y cupo y registrar cambios autorizados. Responsable: equipo de gestión de salas.	Indicador propuesto: Cero identificadores duplicados en pruebas de creación simultánea; 100 % de configuraciones inválidas rechazadas.**Pr= 1:** La restricción de unicidad y las pruebas concurrentes reducen la colisión accidental.	Proyección: 1 × 4 = 4 Baja.

								Ir=4: Una asociación incorrecta que llegara a producirse todavía expondría información entre salas.	
R04	Registro del vínculo entre usuario o sesión y dispositivo (Datos)	Identidad verificable del usuario/sesión y dispositivo autorizado. Integridad y autenticidad.	Un atacante modifica el identificador de dispositivo o usuario enviado por el cliente y sustituye el vínculo legítimo porque el servidor confía en esos datos sin verificarlos.	3	4	12 Media. Los identificadores controlados por el cliente pueden falsificarse; la sustitución permite suplantación o eludir la exclusividad.	Mitigar: Mantener el vínculo en un registro autoritativo del servidor, asociarlo a una identidad verificable y exigir re-autenticación para cambiarlo; revocar el vínculo anterior. Responsable: equipo de identidad y sesiones.	Indicador propuesto: 100 % de pruebas de sustitución de identificadores rechazadas; cambios de dispositivo solo tras re-autenticación y revocación del anterior.**Pr=1:** El servidor deja de aceptar un identificador arbitrario como prueba de identidad y controla cada	Proyección: 1 × 4 = 4 Baja.

								cambio de vínculo.**Ir=4:** Un vínculo falsificado que se aceptara aún permitiría suplantar la sesión o bloquear al usuario.	
R05	Tokens de sesión y estado de conexiones activas (Información)	Emisión, almacenamiento, expiración y revocación de sesiones. Confidencialidad y autenticidad.	Un atacante reutiliza un token filtrado y toma una sesión porque el token dura demasiado o sigue siendo válido después del cierre.	4	4	16 Alta. Un token reutilizable concede acceso mientras sea válido; su robo afecta al usuario y sus salas.	Mitigar: Emitir tokens impredecibles y de vigencia limitada, proteger su almacenamiento y transporte y revocarlos al cerrar sesión o cambiar de dispositivo. Responsable: equipo de sesiones.	Indicador propuesto: 100 % de tokens cerrados o vencidos rechazados; 100 % de pruebas de cambio de dispositivo invalidan la conexión anterior.**Pr=2:** La vigencia limitada y la revocación reducen la ventana de abuso, aunque	Proyección: 2 × 4 = 8 Media Baja.

								todavía puede robarse un token vigente.**Ir=4:** La toma de una sesión válida aún permite actuar como su titular dentro de sus salas.	
R06	Mensajes de texto de las salas (Información)	Contenido, autor y secuencia de mensajes de texto. Confidencialidad, integridad y autenticidad.	Un atacante altera el contenido o el autor de un mensaje y el receptor lo acepta porque faltan autenticación de mensajes y validación de identidad.	3	4	12 Media. Sin comprobaciones criptográficas y de autor, la manipulación es posible; afecta la confianza en la conversación de una sala.	Mitigar: Autenticar al emisor desde su sesión, usar cifrado autenticado en un protocolo revisado y vincular sala, autor y secuencia; rechazar alteraciones y repeticiones. Responsable: equipo de mensajería.	Indicador propuesto: 100 % de mensajes alterados, con autor falso o repetidos rechazados en el conjunto de pruebas; entrega correcta de mensajes válidos. **Pr=1:** Las comprobaciones de identidad, integridad y secuencia reducen la	Proyección: 1 × 4 = 4 Baja.

								aceptación de mensajes manipulados. **Ir=4:** Si se aceptara una falsificación, todavía podría engañar a los participantes y alterar su comunicación.	
R07	Archivos multimedia cargados y compartidos (Datos)	Carga, almacenamiento temporal y entrega de multimedia admitida. Integridad y seguridad del cliente.	Un atacante sube un archivo con contenido activo disfrazado de imagen y ejecuta código en los clientes porque solo se comprueba la extensión.	4	4	16 Alta. La carga acepta datos controlados por usuarios; un archivo peligroso puede afectar a varios receptores de una sala.	Mitigar: Permitir solo formatos definidos, verificar tipo real y tamaño, procesar en un entorno aislado y entregar sin ejecución de contenido activo. Responsable: equipo de multimedia.	Indicador propuesto: 100 % de muestras conocidas de contenido activo y tipos no permitidos rechazadas; ninguna muestra de prueba ejecuta código al visualizarse. **Pr=2:** La validación y el aislamiento reducen	Proyección: 2 × 4 = 8 Media Baja.

								archivos peligrosos, pero permanecen formatos malformados o fallas nuevas del procesador. **Ir=4:** Un archivo aceptado indebidamente todavía puede comprometer a sus receptores.	
R08	Servicio de transporte de comunicaciones (Servicio)	Canales de texto y multimedia entre clientes y servidores. Confidencialidad, integridad y autenticidad.	Un atacante situado en la red intercepta comunicaciones porque se permite un canal sin cifrado o se acepta un certificado inválido.	4	5	20 Alta. Se supone una red no confiable; un canal desprotegido puede exponer conversaciones de múltiples salas.	Mitigar: Exigir transporte cifrado y autenticado, por ejemplo HTTPS/WSS con TLS; validar certificados y rechazar conexiones inseguras. Responsable: equipo de comunicaciones.	Indicador propuesto: 100 % de intentos con transporte inseguro o certificados inválidos rechazados; captura de prueba sin contenido legible de mensajes y archivos.	Proyección: 1 × 5 = 5 Baja.

								Pr=1: La validación del canal y el rechazo de conexiones inseguras reducen la interceptación por la red. **Ir=5:** Si se comprometiera el canal, se mantendría la posible exposición de varias conversaciones.	
R09	Claves criptográficas de cifrado y autenticación (Información)	Generación, distribución, custodia y renovación de claves. Confidencialidad y autenticidad.	Un atacante obtiene una clave criptográfica expuesta en código o registros y descifra o suplanta comunicaciones protegidas	3	5	15 Media. La filtración es posible con una gestión deficiente; el alcance puede incluir varias salas si se reutilizan claves.	Mitigar: Separar claves por alcance, almacenarlas de forma protegida, evitar su registro y distribuirlas por canales autenticados; definir renovación y	Indicador propuesto: Cero claves en repositorios y registros; pruebas de aislamiento entre salas y de renovación/revocación superadas.	Proyección: 2 × 5 = 10 Media.

			con esa clave.				revocación según el protocolo. Responsable: equipo de criptografía.	**Pr=2:** La custodia y separación reducen filtraciones y reutilización, pero permanece el compromiso de un extremo autorizado. **Ir=5:** Una clave comprometida todavía afecta las comunicaciones cubiertas por ella.	
R10	Módulo de administración de salas (Software)	Creación, modificación, consulta y cierre de salas. Integridad y disponibilidad.	Un participante invoca una ruta administrativa y cierra salas porque el servidor solo oculta la interfaz y no	3	5	15 Media. Una autorización limitada a la interfaz puede eludirse; el cierre indebido puede afectar	Mitigar: Autenticar y autorizar cada operación en el servidor, separar el rol administrativo y registrar cambios; confirmar	Indicador propuesto: 100 % de rutas administrativas rechazan usuarios sin rol; cierres y modificaciones tienen autor y	Proyección: 1 × 5 = 5 Media Baja.

			comprueba el rol.			todas las salas.	operaciones destructivas. Responsable: equipo de administración.	registro verificables. **Pr=1:** La autorización del servidor en cada ruta reduce el acceso de participantes a funciones administrativas. **Ir=5:** Un acceso administrativo indebido que persista todavía permitiría alterar o cerrar varias salas.	
R11	Servicio de admisión y autorización por sala (Servicio)	Ingreso y autorización de cada mensaje, archivo y recurso de sala. Confidencialidad y mínimo privilegio.	Un miembro de una sala accede a mensajes o archivos de otra al cambiar su identificador porque solo se valida el	4	4	16 Alta. Las solicitudes con identificadores manipulados son viables si solo hay	Mitigar: Comprobar membresía y permiso en cada operación, vincular solicitudes a la sesión y sala autorizadas y validar cupo de	Indicador propuesto: 100 % de pruebas de envío, lectura y descarga entre salas no autorizadas rechazadas; cupo máximo	Proyección: 1 × 4 = 4 Baja.

			acceso al conectar.			control inicial; pueden exponer contenido de otra sala.	forma atómica al ingresar. Responsable: equipo de autorización.	respetado en pruebas concurrentes. **Pr=1:** La comprobación por solicitud reduce el uso de permisos de una sala para acceder a otra. **Ir=4:** Un acceso cruzado aceptado indebidamente seguiría exponiendo la comunicación de una sala.	
R12	Gestor de exclusividad de dispositivo y cierre de sesiones (Servicio)	Un dispositivo activo por usuario/sesión y cierre seguro de conexiones. Integridad y autenticidad.	Dos dispositivos se conectan simultáneamente con la misma identidad y ambos quedan activos	4	4	16 Alta. La concurrencia puede eludir una verificación separada del registro; se incumple el	Mitigar: Usar un registro autoritativo con unicidad y actualización atómica; rechazar la segunda conexión o reemplazar la	Indicador propuesto: Cero casos con más de un dispositivo activo por identidad en pruebas concurrentes y de reconexión;	Proyección: 1 × 4 = 4 Baja.

			porque la comprobación y el registro no son atómicos.			requisito de dispositivo único.	anterior según política, revocando sus tokens. Responsable: equipo de sesiones.	100 % de cierres invalidan tokens. **Pr=1:** La unicidad y la operación atómica reducen la carrera entre conexiones y el uso de sesiones antiguas. **Ir=4:** Una doble sesión aceptada todavía permitiría actividad simultánea no autorizada.	
R13	Módulo de validación y detección de esteganografía (Software)	Análisis previo de formatos admitidos y contenido sospechoso. Cumplimiento de la política multimedia.	Un archivo con contenido oculto elude el analizador y se comparte porque la	4	4	16 Alta. Las técnicas de ocultación varían y la detección no es universal; un falso	Mitigar: Definir formatos y técnicas cubiertas, combinar validaciones y estegoanálisis y poner en	Indicador propuesto: Metas propuestas: detección ≥ 90 % y falsos positivos ≤ 5 % en un corpus	Proyección: 3 × 4 = 12 Media.

			detección solo revisa metadatos o técnicas limitadas.			negativo permite eludir la política de contenido.	cuarentena los sospechosos; evaluar con un corpus etiquetado. Responsable: equipo de análisis multimedia.	etiquetado independiente, con tamaño y técnicas documentados. **Pr=3:** Cumplir las metas reduce fallas conocidas, pero quedan técnicas no cubiertas y esos resultados no demuestran detección universal. **Ir=4:** Un archivo oculto no detectado todavía puede infringir la política y servir como canal encubierto.	
R14	Almacenamiento aislado de cuarentena	Zona de cuarentena propuesta como política	Un usuario descarga un archivo bloqueado	3	4	12 Media. Una separación	Mitigar: Mantener cuarentena privada y	Indicador propuesto: 100 % de intentos de acceso	Proyección: 1 × 4 = 4 Baja.

	de archivos sospechosos (Infraestructura)	para archivos sospechosos. Aislamiento y control de acceso.	mediante su enlace directo porque la cuarentena comparte permisos o rutas públicas con el contenido aprobado.			solo visual puede eludirse con enlaces directos; el archivo retenido vuelve a circular.	separada, sin ejecución ni rutas de descarga para participantes; autorizar revisión y liberación con auditoría. Responsable: equipo de almacenamiento multimedia.	directo de participantes a archivos en cuarentena rechazados; ninguna muestra se ejecuta en almacenamiento. **Pr=1:** El aislamiento y la autorización del servidor reducen la descarga directa y la liberación indebida. **Ir=4:** Una muestra liberada por error todavía puede afectar a quienes la reciban.	

R15	Registros de auditoría y alertas de seguridad (Datos)	Eventos de acceso, sesiones, administración y multimedia sospechosa. Integridad y trazabilidad.	Un atacante borra eventos de ingreso o archivos sospechosos para ocultar sus acciones porque la aplicación tiene permiso para modificar sus propios registros históricos.	3	4	12 Media. Los registros con permisos compartidos pueden alterarse tras un compromiso; se dificulta detectar y reconstruir incidentes.	Mitigar: Centralizar registros de solo anexado, separar permisos y alertar pérdidas de eventos; registrar acciones sin guardar claves, tokens ni contenido privado innecesario. Responsable: equipo de monitoreo.	Indicador propuesto: 100 % de borrados o cambios desde la aplicación rechazados; alerta de archivo sospechoso recibida en ≤ 60 s como objetivo. **Pr=1:** Los permisos separados y las alertas reducen el ocultamiento de acciones y permiten detectar interrupciones. **Ir=4:** Una pérdida de evidencias que ocurra aún dificultaría investigar incidentes.	Proyección: 1 × 4 = 4 Baja.